BCSE-1501
Network Security

Dr. Arvind Prasad
Department of CEA
GLA University, Mathura

Cryptography & Trust Management

What is Cryptography?

Cryptography is the science of securing information by transforming readable data (**plaintext**) into an unreadable form (**ciphertext**) using **mathematical algorithms and secret keys**, ensuring that only authorized parties can access or verify the data.

Core Objectives

- **Confidentiality** – Prevents unauthorized data disclosure
- **Integrity** – Ensures data is not altered in transit
- **Authentication** – Verifies the identity of communicating parties
- **Non-repudiation** – Prevents denial of actions (e.g., digital signatures)

How It Works

- Plaintext → **Encryption Algorithm + Key** → Ciphertext
- Ciphertext → **Decryption Algorithm + Key** → Plaintext

Why Cryptography is Essential

- Secures **internet communication (HTTPS, TLS)**
- Protects **passwords, transactions, emails, cloud data**
- Forms the backbone of **trust in distributed systems**

GLA UNIVERSITY MATHURA

Trust in Distributed Systems

Trust is the assumption that a remote entity will behave as expected, even in the presence of **partial failures, malicious nodes, or untrusted networks**.

Why Trust is Challenging

- No single global authority
- Nodes operate independently
- Communication over insecure networks
- Possibility of compromised or malicious participants

Foundations of Trust

- **Authentication** – Who are you?
- **Authorization** – What are you allowed to do?
- **Integrity** – Has data been altered?
- **Availability** – Can services be reliably accessed?

How Trust is Established

- **Cryptography:** Encryption & digital signatures
- **PKI:** Certificate Authorities and trust chains
- **Protocols:** TLS, Kerberos
- **Models:** Zero Trust, Web of Trust

GLA UNIVERSITY MATHURA

Symmetric Cryptography

Symmetric Cryptography is an encryption technique in which the **same secret key** is used for both **encryption and decryption** of data.

How It Works

- Sender encrypts plaintext using a **shared secret key**
- Encrypted data (ciphertext) is transmitted
- Receiver decrypts using the **same key**

Key Characteristics

- **Fast and efficient** (suitable for large data)
- Requires **secure key distribution**
- Key compromise breaks confidentiality

Types

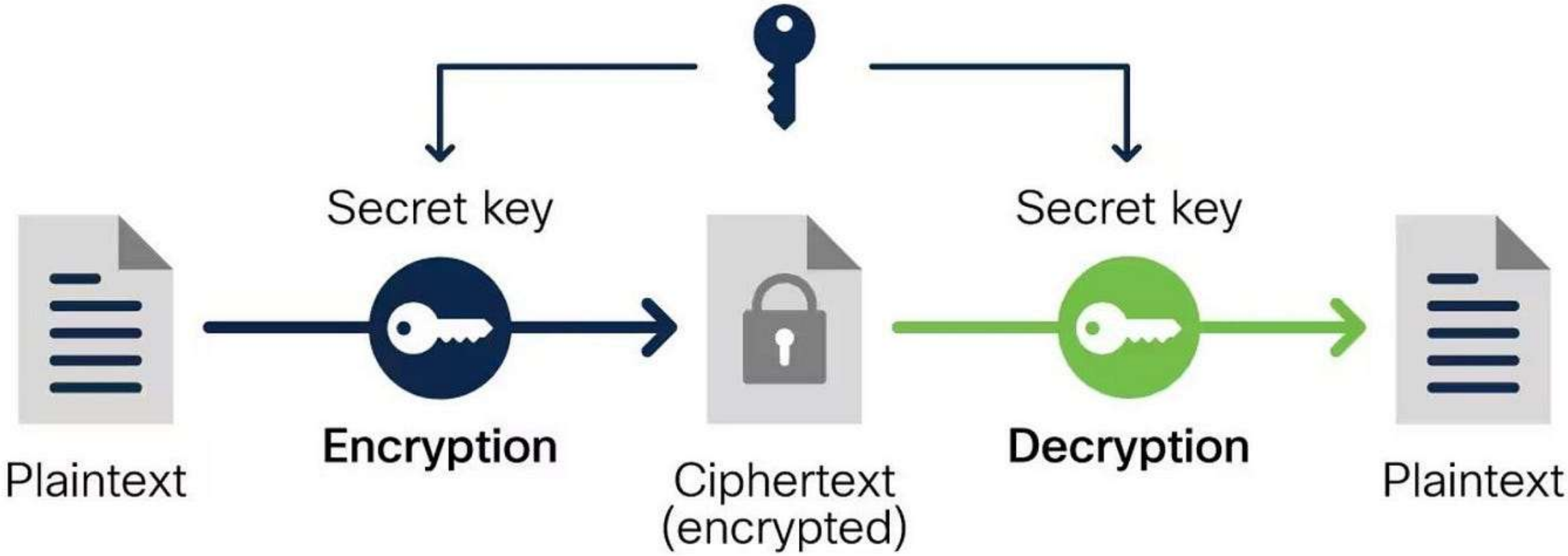
- **Block Ciphers:** AES, DES
- **Stream Ciphers:** RC4 (deprecated), ChaCha20

Weaknesses of Symmetric Cryptography (Short)

- **Key distribution problem** – Securely sharing the secret key is difficult.
- **Poor scalability** – Requires many keys as the number of users increases.
- **Single key compromise** – If the key is leaked, all encrypted data is exposed.

GLA UNIVERSITY MATHURA

Symmetric encryption



Asymmetric Cryptography

Asymmetric Cryptography uses a **pair of mathematically related keys**:

- **Public Key** – shared openly
- **Private Key** – kept secret by the owner

How It Works

- Data encrypted with a **public key** can only be decrypted using the corresponding **private key**
- Enables secure communication without prior key sharing

Key Features

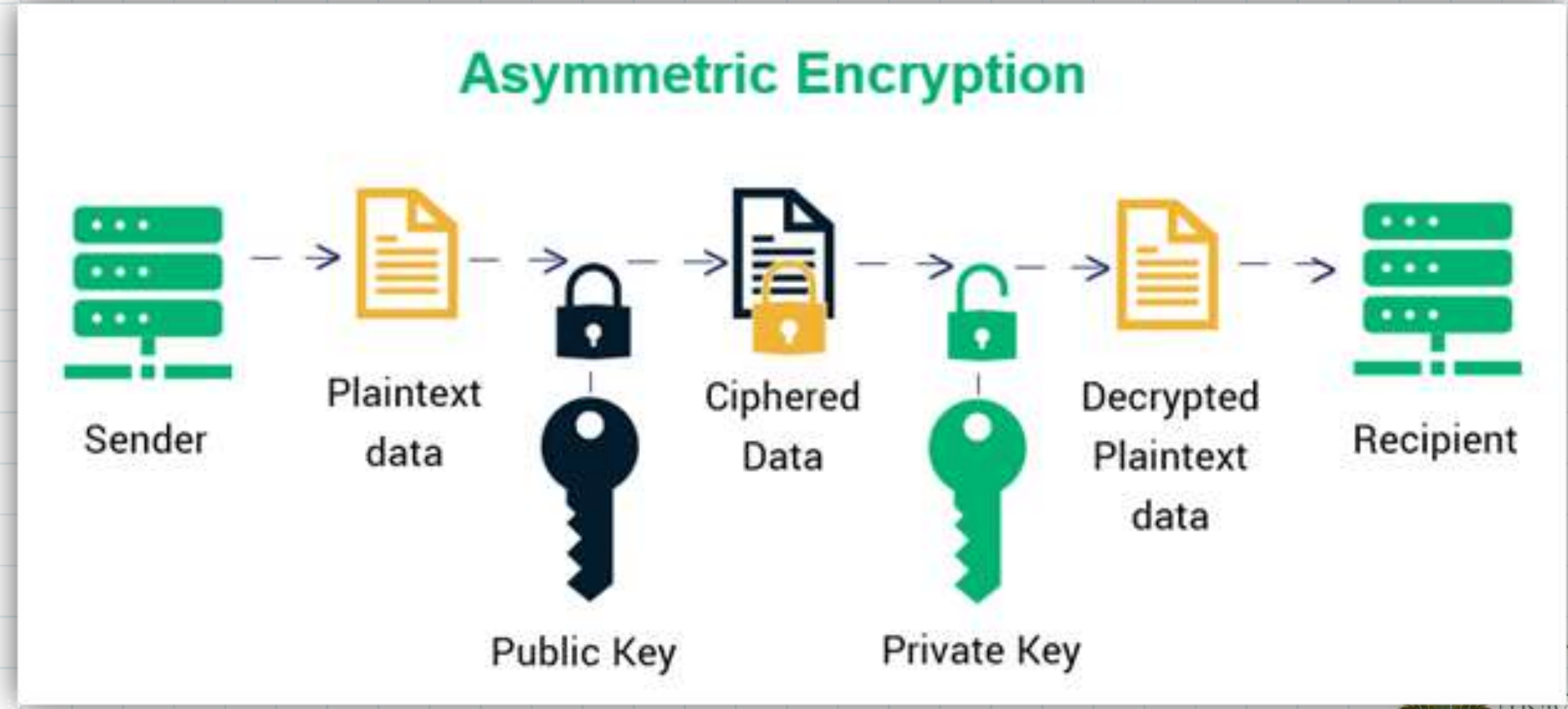
- Solves the **key distribution problem**
- Supports **authentication and digital signatures**
- Computationally **slower** than symmetric cryptography

Common Algorithms

- RSA
- Diffie–Hellman (Key Exchange)

GLA UNIVERSITY MATHURA

Asymmetric Key Cryptosystems (Public Key Cryptography)



Public Key

The public key is used to encrypt messages.

It can be shared with anyone who wants to send a secure message to the key owner.

Private Key

The private key is used to decrypt messages that were encrypted with the corresponding public key.

It must be kept secret to ensure that only the intended recipient can read the encrypted messages.

Symmetric vs Asymmetric Cryptography

Aspect	Symmetric Cryptography	Asymmetric Cryptography
Keys Used	Single shared secret key	Public–private key pair
Encryption Speed	Very fast	Slower
Key Distribution	Difficult and insecure	Easy
Scalability	Poor	Good
Authentication	Not inherent	Supported
Digital Signatures	Not supported	Supported
Computational Cost	Low	High
Common Algorithms	AES, DES	RSA, ECC
Typical Use	Bulk data encryption	Key exchange, authentication
Real-World Example	Disk encryption, VPN tunnels	HTTPS, PKI, email security

GLA UNIVERSITY MATHURA

HASH FUNCTIONS

A **Hash Function** is a mathematical function that transforms an input message of **arbitrary length** into a **fixed-length output**, known as the **hash value**, **digest**, or **message digest**.

$$H: \{0,1\}^* \rightarrow \{0,1\}^n,,$$

Where:
H = hash function,
input = any binary string of arbitrary length,
output = fixed-length string (n bits).
Hash functions are widely used in cryptography to ensure **data integrity**, **authentication**, and **digital signature verification**.

GLA UNIVERSITY MATHURA

SHA (Secure Hash Algorithm)

SHA is a family of **cryptographic hash functions** designed to ensure **data integrity and authenticity** by producing a fixed-length hash from input data of arbitrary size.

SHA Family

- **SHA-1** – 160-bit hash *(deprecated)*
- **SHA-2** – SHA-224, **SHA-256**, SHA-384, SHA-512
- **SHA-3** – Latest standard, different internal design

Key Properties

- One-way (irreversible)
- Fixed-length output
- Collision-resistant *(for SHA-2, SHA-3)*
- Deterministic

Security Status

- ❌ SHA-1: Vulnerable to collision attacks
- ✓ SHA-256 / SHA-3: Secure and widely recommended

Real-World Uses

- Password hashing (with salt)
- Digital signatures
- TLS/SSL, Blockchain
- File and message integrity verification

GLA UNIVERSITY MATHURA

MD5 (Message Digest Algorithm 5)

MD5 is a **cryptographic hash function** that produces a **128-bit (16-byte) hash value** from an input of arbitrary length.

Key Characteristics

- Fixed-length output (128-bit hash)
- Deterministic (same input → same hash)
- Fast computation
- One-way function (no decryption)

Intended Security Properties

- Pre-image resistance (Given a hash value, it should be practically impossible to find any input that produces that hash.)
- Second pre-image resistance (practically impossible to find a *different* input that produces the same hash.)
- Collision resistance ✗ *(broken)*

Major Weakness

- **Collision attacks** are practical
- Two different inputs can generate the **same hash**
- Not secure for cryptographic integrity or authentication

GLA UNIVERSITY MATHURA

AES (Advanced Encryption Standard)

AES is a **symmetric block cipher** standard used to securely encrypt data.

Key Features

- Block size: **128 bits**
- Key sizes: **128 / 192 / 256 bits**
- Very fast and secure
- Resistant to known practical attacks

Used In

- Disk & database encryption
- VPNs
- TLS session encryption
- Wi-Fi security (WPA2/WPA3)

Why is it so strong?

- **It's a "Round" System:** AES doesn't just do those steps once. It does them **10 to 14 times** (called "Rounds").
- **Math Power:** To "guess" the key for the strongest version (AES-256), a supercomputer would need to work for billions of years.
- **Everywhere:** It's used by your phone (iMessage/WhatsApp), your bank, and even the government for "Top Secret" files.

GLA UNIVERSITY MATHURA

RSA (Rivest–Shamir–Adleman)

RSA is an **asymmetric cryptographic algorithm** based on the mathematical difficulty of factoring large prime numbers.

Key Features

- Uses **public–private key pair**
- Enables **secure key exchange**
- Supports **digital signatures**
- Slower than symmetric encryption

Used In

- TLS handshakes
- Digital certificates
- Secure email
- Authentication systems

If Person **A** wants to send a message securely to Person **B**:

- Person A **encrypts** the message using Person B's **Public** Key.
- Person B **decrypts** the message using their **Private** Key.

Key Generation

Select two distinct prime numbers p and q

Compute $n=p\times q$, , where n is called the modulus for encryption and decryption.

Compute $\varphi(n)=(p-1)\times(q-1)$

Choose an integer e such that $1 < e < \varphi(n)$ and $GCD(e,\varphi(n))=1$ (i.e., e is co-prime to $\varphi(n)$).

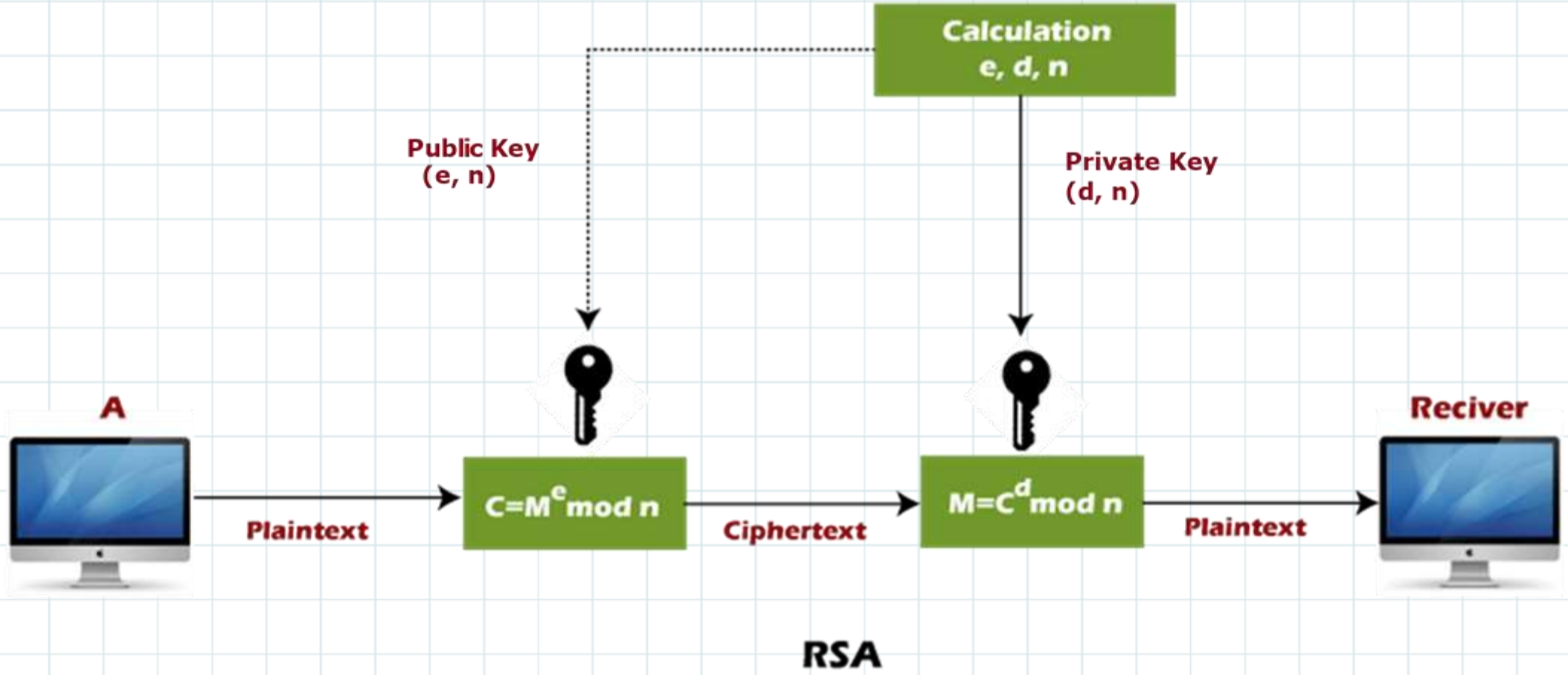
Find d: Satisfies $(e\times d) \bmod \varphi(n)=1$

Encryption:

Ciphertext $c = m^e \bmod n$, where m is the plaintext.

Decryption:

Plaintext $m = c^d \bmod n$


Calculation
e, d, n
Public Key
(e, n)
Private Key
(d, n)
A
Reciver
C=M^e mod n
M=C^d mod n
Plaintext
Ciphertext
Plaintext

RSA

Example

Step 1: in the first step, select two large prime numbers, **p** and **q**.

p = 3

q = 11

Step 2: we calculate

n = p x q

n = 3 x 11

n = 33

where **n** is called the modulus for encryption and decryption.

GLA UNIVERSITY MATHURA

Example

Step 3: calculate

$$\varphi(n) = (p - 1) * (q-1)$$

$$\varphi(n) = (3 - 1) * (11 - 1)$$

$$\varphi(n) = 2 * 10$$

$$\varphi(n) = 20$$

Example

Step 4: We need to choose e such that $1<e<\phi(n)$ and $GCD(e,\phi(n))=1$ (i.e., e is co-prime with $\phi(n)$).

Let's choose e=3, as it satisfies

$GCD(3,20)=1$

GLA UNIVERSITY MATHURA

Example

Step 5: Find d

$(e \times d) \bmod \phi(n) = 1$

To find d, we solve the equation $(3 \times d) \bmod 20$

By trial, **d=7** satisfies this equation, as

$(3 \times 7) \bmod 20$

$= 21 \bmod 20 = 1$

Example

Step 6: Public and Private Keys

Public Key: (e=3,n=33)
Private Key: (d=7,n=33)

Example

Step 7: Encryption

To encrypt a message m, use the formula:

$$c = m^e \bmod n$$

Let's encrypt the message m=7

$c=7^3 \bmod 33$

$c=343 \bmod 33$

$c= 343 \div 33 = 10$ remainder 13

So, c=13.

Encrypted message: c=13

GLA UNIVERSITY MATHURA

Example

Step 6: Decryption

To decrypt the ciphertext c=13, use the formula:
$m = c^d \bmod n$

$m=13^7 \bmod 3$
$=62,748,517 \bmod 33$
$= 7$ which is the original message.

GLA UNIVERSITY MATHURA

SSL (Secure Sockets Layer)

The Secure Socket Layer (SSL) is a **cryptographic protocol** designed to provide secure communication over a computer network. It was developed by **Netscape** in the 1990s to establish an encrypted link between the web server and a web browser. SSL operates by using encryption to secure the transmission of data ensuring that sensitive information such as credit card details and personal data remains confidential.

Key Features of SSL

- **Encryption**: It uses encryption algorithms to protect data during transmission.
- **Authentication**: SSL uses a handshake process to authenticate both the client and server, ensuring each party is legitimate and not an imposter.
- **Data Integrity**: SSL digitally signs transmitted data to detect any tampering, ensuring that the data received is exactly what was sent.

GLA UNIVERSITY MATHURA

Transport Layer Security (TLS)

The Transport Layer Security (TLS) is the successor to SSL and is designed to provide improved security and efficiency. TLS was developed as an enhancement of SSL to the address various vulnerabilities and to the incorporate modern cryptographic techniques.

Key Features

- Secure handshake using asymmetric crypto
- Fast data encryption using symmetric crypto
- Certificate-based authentication
- Supports Perfect Forward Secrecy

Versions

- TLS 1.2 – Widely used
- TLS 1.3 – Faster and more secure

Used In

- HTTPS
- Secure email
- VPNs
- Cloud & API security

GLA UNIVERSITY MATHURA

Public Key Infrastructure

Public Key Infrastructure (PKI) is a framework of **policies, roles, hardware, software, and procedures** used to **create, manage, distribute, validate, and revoke digital certificates**.

Core Components

- **Certificate Authority (CA)** – Issues and signs certificates
- **Registration Authority (RA)** – Confirms the identity of a user, device, or organization **before** a certificate is issued.
- **Digital Certificates** – Bind public keys to identities
- **Trust Chain** – Root CA → Intermediate CA → End Entity
- **Revocation Mechanisms** – CRL (Certificate Revocation List), OCSP (Online Certificate Status Protocol).

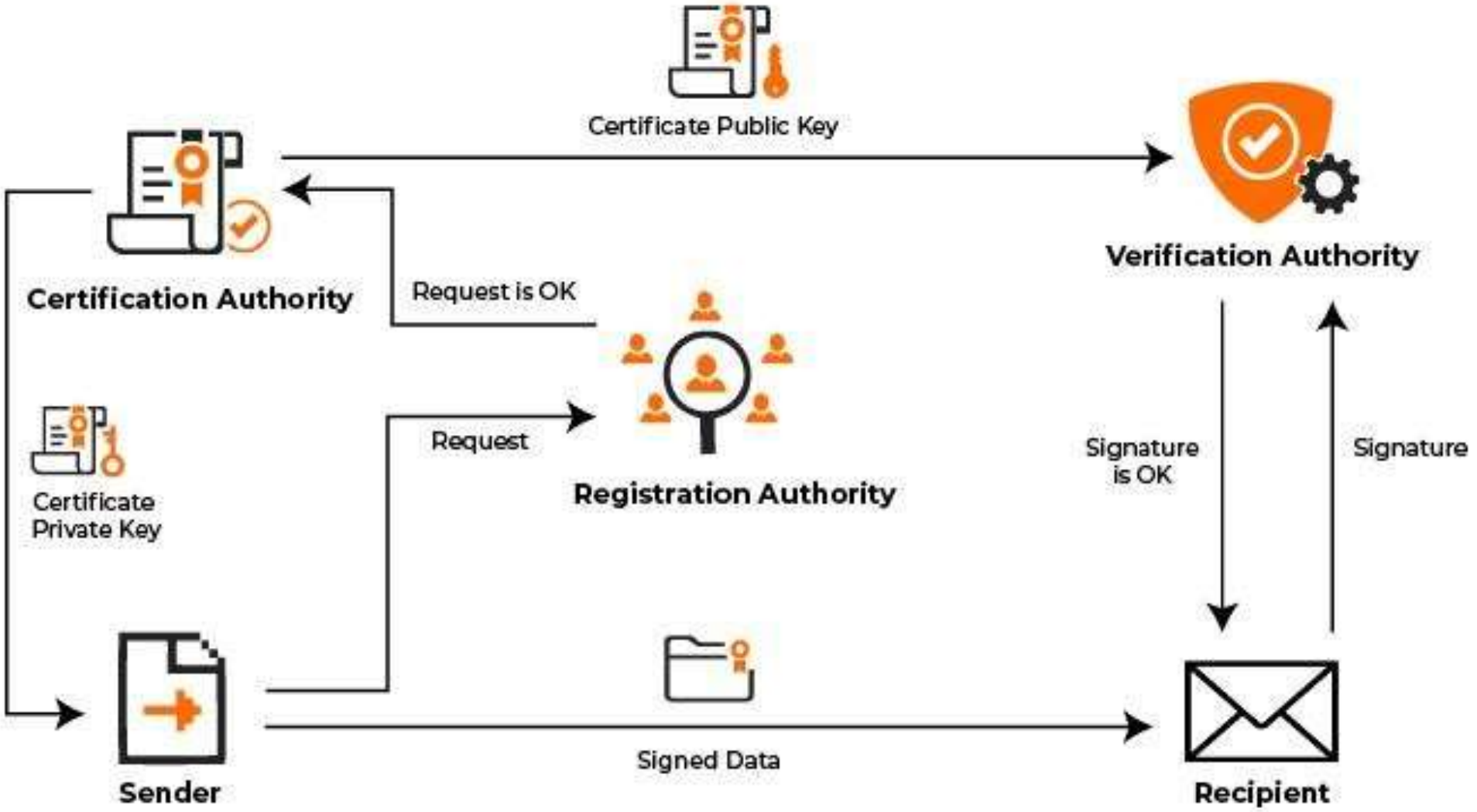
How PKI Establishes Trust

- Identity verification → Certificate issuance
- Certificate validation via trust chain
- Secure communication using public keys

Why PKI is Needed

- Enables **authentication**, **confidentiality**, and **non-repudiation**
- Prevents **impersonation** and **MITM attacks**
- Forms the trust backbone of the Internet

Public Key Infrastructure



Digital Signatures,

A **Digital Signature** is a cryptographic mechanism that uses **asymmetric cryptography and hash functions** to verify the **authenticity, integrity, and non-repudiation** of digital data.

How It Works

- Message is hashed (e.g., SHA-256)
- Hash is encrypted using the **sender's private key**
- Receiver decrypts using **sender's public key**
- Hashes are compared for verification

Security Guarantees

- **Authentication** – Confirms sender identity
- **Integrity** – Detects data modification
- **Non-repudiation** – Sender cannot deny signing

Common Algorithms

- RSA

Real-World Applications

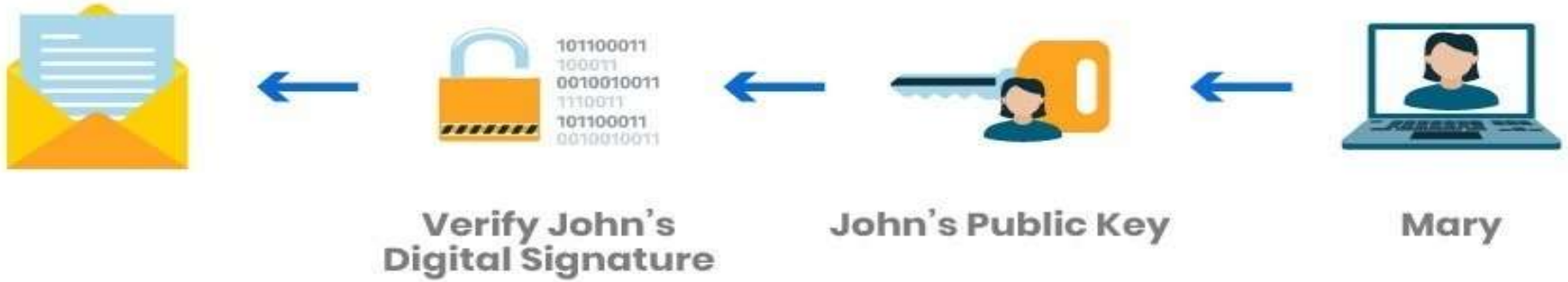
- Secure email
- Digital contracts
- Blockchain transactions

Digital Signature

1. John uses his private key to generate the digital signature of the email and sends the email to Mary.



2. Upon receiving the email, Mary verifies John's digital signature with John's public key



GLA UNIVERSITY MATHURA

Certificate Authorities (CAs)

A **Certificate Authority (CA)** is a **trusted organization** that **issues, signs, and manages digital certificates**, binding a **public key** to a verified identity.

Role of a CA

- Verifies the identity of entities (users, servers, organizations)
- Issues **X.509 digital certificates**
- Digitally signs certificates to establish trust
- Manages certificate **revocation** and **expiry**

Trust Hierarchy

- **Root CA** – Ultimate trust anchor
- **Intermediate CA** – Delegated authority
- **End-Entity Certificate** – Server/User certificate

  (Trust flows from Root → Intermediate → End Entity)

Why CAs are Important

- Prevent **impersonation** and **MITM attacks**
- Enable secure **TLS/HTTPS communication**
- Form the backbone of **Internet trust**

Certificate Revocation

- **CRL (Certificate Revocation List)**
- **OCSP (Online Certificate Status Protocol)**

GLA UNIVERSITY MATHURA

Cryptographic Key Management

Cryptographic Key Management refers to the **secure generation, storage, distribution, rotation, and revocation of cryptographic keys** throughout their lifecycle.

Key Lifecycle

- **Key Generation** – Strong randomness, secure algorithms
- **Key Distribution** – Secure sharing of keys (e.g., RSA, Diffie–Hellman)
- **Key Storage** – Protected using HSM, TPM, secure vaults
- **Key Rotation & Expiry** – Limits damage from key compromise
- **Key Revocation** – Invalidates compromised or expired keys

Key Distribution Methods

- Manual / Pre-shared keys (small systems)
- **Asymmetric key exchange** (TLS, PKI)
- Centralized systems (Kerberos, KMS)

Why It Is Critical

- Weak key management breaks **strong cryptography**
- Prevents **key leakage**, **impersonation**, and **MITM attacks**
- Essential for **cloud, enterprise, and IoT security**

GLA UNIVERSITY MATHURA

Cryptographic Key Distribution

Cryptographic Key Distribution is the process of **securely sharing cryptographic keys** between communicating parties so that encrypted communication can take place.

Why It Is Challenging

- Communication occurs over **untrusted networks**
- Keys must remain **confidential and authentic**
- Vulnerable to **Man-in-the-Middle (MITM) attacks**

Common Key Distribution Methods

- **Pre-shared Keys (PSK)** – Simple but poor scalability
- **Asymmetric Key Exchange** – Diffie–Hellman
- **Trusted Third Party** – Kerberos, centralized servers
- **PKI-based Distribution** – Certificates and CAs

Real-World Examples

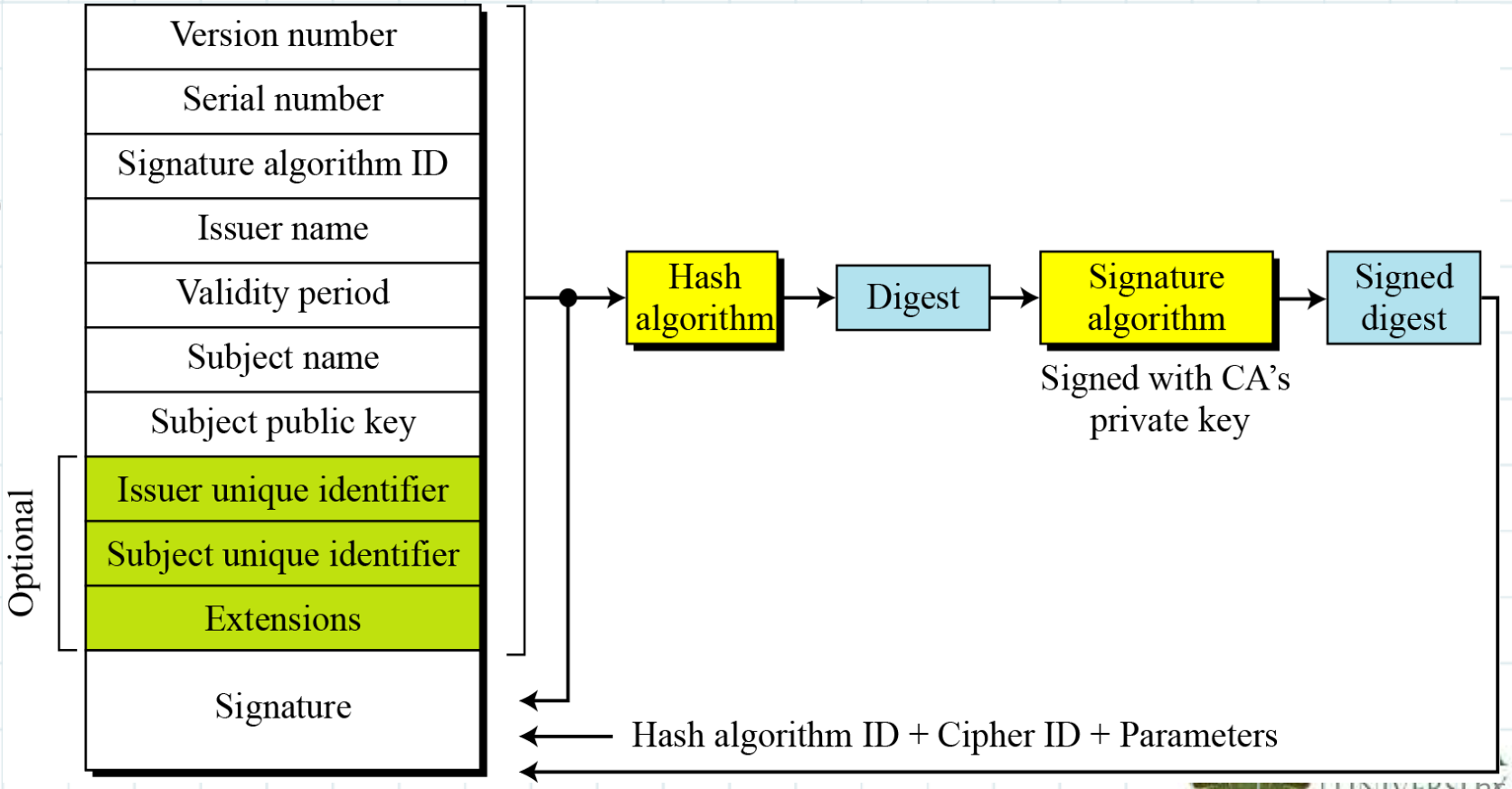
- TLS uses asymmetric cryptography to exchange symmetric keys
- Kerberos distributes session keys via a trusted server
- Wi-Fi security uses PSK or enterprise authentication

X.509 Certificates

An **X.509 certificate** is a digital certificate that uses the **X.509 public key infrastructure (PKI) standard** to verify the identity of a party and securely associate that identity with a **public key**. It's most commonly used in **SSL/TLS**, **HTTPS**, **email security (S/MIME)**, **code signing**, and **VPNs**.

Where They're Used

- HTTPS / TLS (websites)
- Email security (S/MIME)
- VPNs
- Code signing
- Authentication in enterprise systems
- IoT device identity



X.509 Certificates Fields

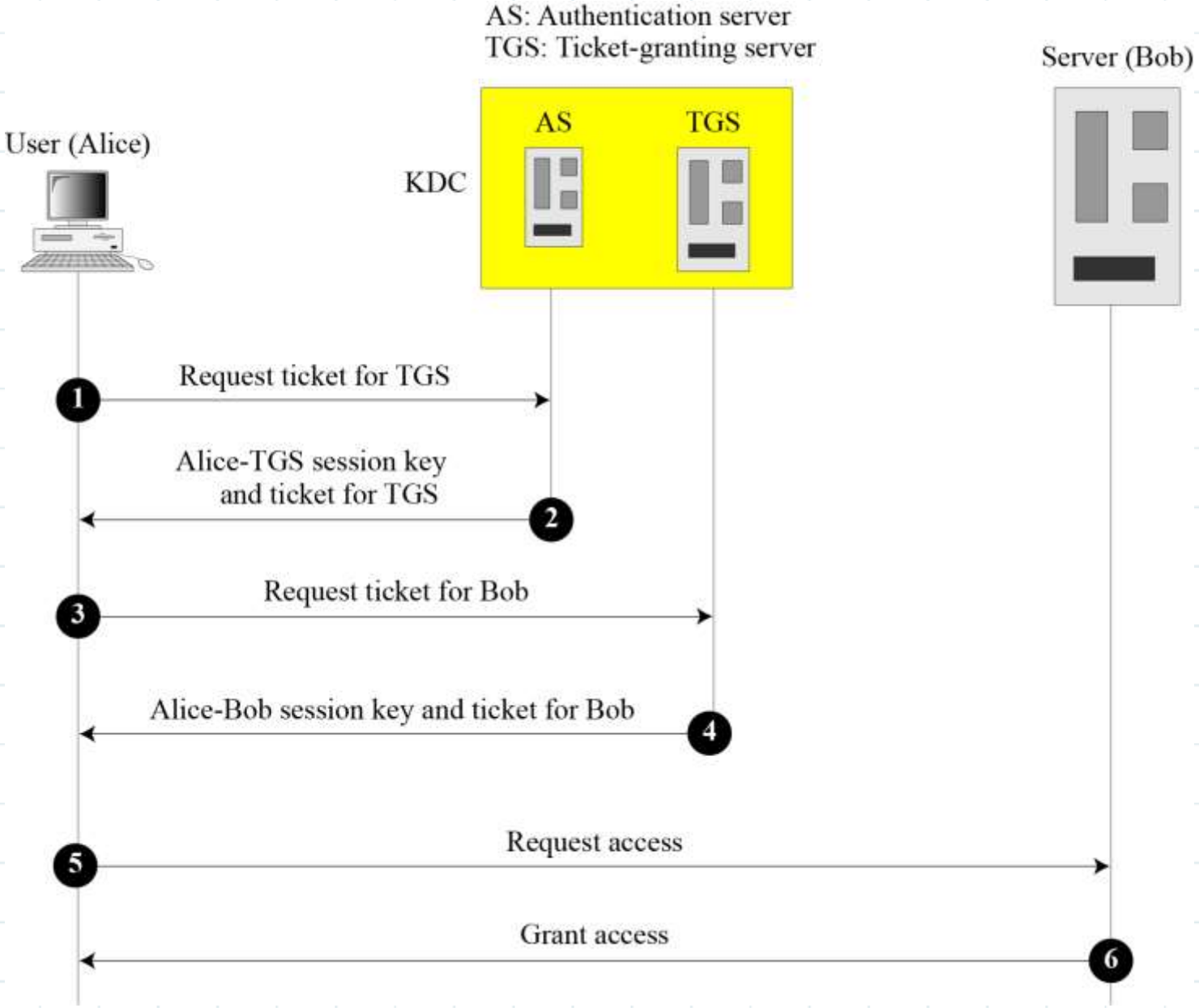
1. **Version number** – Specifies the X.509 certificate version and supported features.
2. **Serial number** – Uniquely identifies the certificate issued by the CA.
3. **Signature algorithm ID** – Indicates the hash and signature algorithm used by the CA.
4. **Issuer name** – Identifies the Certificate Authority that issued the certificate.
5. **Validity period** – Defines the start and expiry dates of the certificate.
6. **Subject name** – Identifies the entity to which the certificate belongs.
7. **Subject public key** – Contains the public key of the certificate owner.
8. **Issuer unique identifier** – Uniquely distinguishes the issuing CA (optional).
9. **Subject unique identifier** – Uniquely distinguishes the certificate holder (optional).
10. **Extensions** – Specify additional constraints and usage policies of the certificate.
11. **Hash algorithm** – Generates a fixed-length hash of the certificate data.
12. **Digest** – The hash value produced from the certificate contents.
13. **Signature algorithm** – Encrypts the digest using the CA's private key.
14. **Signed digest** – The digital signature ensuring integrity and authenticity.
15. **Signature** – Final certificate field containing the CA's digital signature.

Kerberos

Kerberos is a **network authentication protocol** used in cryptography to securely authenticate users and services in an **insecure network** (like the internet or a corporate LAN). **Kerberos** provides a centralized authentication server whose function is to authenticate users to servers and servers to users. In Kerberos Authentication server and database is used for client authentication. Kerberos runs as a third-party trusted server known as the Key Distribution Center (KDC). Each user and service on the network is a principal.
It was developed by MIT and is widely used in **enterprise environments**, especially with **Microsoft Active Directory**.

- **Trusted Third Party:** The Key Distribution Center (KDC) is the heart of Kerberos.
- **Symmetric Key Cryptography:** It uses shared secret keys, not public-private key pairs like in PKI.
- **Tickets, Not Passwords:** After you authenticate, you get a "ticket" you can reuse to access multiple services without re-entering your password.

Kerberos servers



Authentication Server (AS):
Verifies the user's identity when they first log in and issues a Ticket-Granting Ticket (TGT).

Ticket-Granting Server (TGS):
Uses the TGT to issue service tickets, allowing the user to access specific services without logging in again.

Real Server (Service Server / Application Server):
The actual server that provides the requested service (e.g., file server, database).
It accepts the service ticket and grants access if it's valid.

Network Security & Protocols

CIA Triad

The **CIA Triad** is a foundational model in **cybersecurity** that defines the three core objectives of protecting information and information systems. The CIA Triad is not just a definition model; it is a **decision-making framework** used to:

- Design secure systems
- Evaluate security risks
- Prioritize controls
- Analyze incidents

GLA UNIVERSITY MATHURA

1. Confidentiality

Goal: Prevent unauthorized access to information.
Confidentiality ensures that sensitive data is accessible **only to authorized users, systems, or processes**.

Common mechanisms:

- Encryption (AES, RSA, TLS)
- Access control (authentication & authorization)
- Data classification and handling policies
- Network security (firewalls, VPNs)

Threats to confidentiality:

- Data breaches
- Eavesdropping
- Insider threats
- Phishing attacks

Confidentiality protects:

- Data at rest
- Data in transit
- Data in use

GLA UNIVERSITY MATHURA

2. Integrity

Goal: Ensure information is accurate, complete, and unaltered.
Integrity guarantees that data is not modified **accidentally or maliciously** without authorization.

Common mechanisms:

- Hash functions (SHA-256)
- Digital signatures
- Checksums
- Version control and audit logs
- Input validation

Threats to integrity:

- Malware
- Man-in-the-middle attacks
- Unauthorized data modification
- Software bugs

Integrity ensures:

- Authenticity (who created the data)
- Non-repudiation (cannot deny actions)
- Consistency across systems

GLA UNIVERSITY MATHURA

3. Availability

Goal: Ensure systems and data are accessible when needed.
Availability ensures that authorized users can access information and services **without interruption**.

Common mechanisms:

- Redundancy and failover systems
- Backups and disaster recovery plans
- Load balancing
- DDoS protection
- Regular system maintenance

Threats to availability:

- Denial-of-Service (DoS/DDoS) attacks
- Hardware failures
- Power outages
- Natural disasters

Availability means:

- System uptime
- Performance under load
- Resilience to failure
- Rapid recovery

Network Services

A **network service** is a software-based functionality running on a system that **provides resources or capabilities to other systems over a network** using standard protocols. Network services provide functionality over a network, but each exposed service increases attack surface and must be securely configured to maintain confidentiality, integrity, and availability.

Services = what is offered, Ports = where it is offered.

Network services:

- Expose systems to external networks
- Define the **attack surface**
- Are primary targets in cyberattacks
- Must be securely configured and continuously monitored

Services as Attack Surfaces

- Each running service:
- Opens a communication channel
- Increases system exposure
- Must be justified by business need

Golden rule: If a service is not required, it should not be running.

GLA UNIVERSITY MATHURA

Classification of Network Services

1 Application Services

Provide end-user functionality.

Examples:

- Web services (HTTP/HTTPS)
- Email services (SMTP, POP3, IMAP)
- File transfer services (FTP, SFTP)

2 Infrastructure Services

Support core network operations.

Examples:

- DNS (name resolution)
- DHCP (IP assignment)
- NTP (time synchronization)

3 Management Services

Used for administration and remote access.

Examples:

- SSH
- RDP
- SNMP

GLA UNIVERSITY MATHURA

Common Network Services and Their Roles

1 HTTP / HTTPS (Web Service): Provides access to web applications and websites.

- HTTP: Unencrypted
- HTTPS: Encrypted using TLS

Security risks: SQL injection, XSS, certificate misconfiguration

2 FTP / SFTP (File Transfer Service): Used to transfer files between systems.

- FTP: Plaintext
- SFTP: Encrypted over SSH

Security risks: Credential theft, unauthorized file access

3 SMTP / POP3 / IMAP (Email Services): Handle sending and receiving of emails.

Security risks: Email spoofing, phishing, malware delivery

4 DNS (Domain Name System): Translates domain names into IP addresses.

Security risks: DNS spoofing, cache poisoning, amplification attacks

GLA UNIVERSITY MATHURA

Network Ports

A **network port** is a **logical communication endpoint** that allows multiple network services to operate on a single IP address by distinguishing traffic for different applications.

IP identifies the system, port identifies the service/process.

Why Ports Are Important in Network Security

- Define **entry and exit points** for network traffic
- Control **which services are reachable**
- Represent the **primary attack surface**
- Are the basis of **firewall and IDS rules**

An open port directly indicates a listening service.

Ports as Attack Vectors: Common Attacks

- Port scanning
- Service enumeration
- Exploitation of open ports

GLA UNIVERSITY MATHURA

Classification of Port Numbers

1 Well-Known Ports (0–1023)

- Reserved for standard services
- Require administrative privileges

Examples:

- 80 → HTTP
- 443 → HTTPS
- 22 → SSH

Security concern: Attackers scan these first due to predictability.

2 Registered Ports (1024–49151)

- Assigned to vendor or application services

Examples:

- 3306 → MySQL
- 3389 → RDP

Security concern: Often exposed unintentionally.

3 Dynamic / Ephemeral Ports (49152–65535)

- Temporarily assigned to client applications
- Used for outbound connections

Security concern: Misconfigured firewalls may allow abuse.

GLA UNIVERSITY MATHURA

TCP/IP Communication Flags

TCP flags are **control bits** in the TCP header that manage **connection establishment, data transfer, and termination** between two hosts.
They define **how a TCP session behaves**.

Common TCP Flags:

SYN (Synchronize): Used to **initiate a TCP connection**. It is the first step of the three-way handshake and synchronizes sequence numbers between client and server.

ACK (Acknowledgment): Confirms that data or a packet has been **successfully received**. Almost all TCP packets after connection setup carry the ACK flag.

FIN (Finish): Used for **graceful termination** of a TCP connection, indicating that the sender has no more data to transmit.

Example: When you close a website tab, the browser sends a **FIN** packet to close the TCP session properly.

GLA UNIVERSITY MATHURA

Cont…

RST (Reset): Abruptly terminates a connection due to errors, invalid ports, or unexpected packets. No graceful shutdown occurs.
Example: Connecting to a closed port (e.g., telnet host 81) often results in an **RST** packet.

PSH (Push): Instructs the receiver to **immediately deliver data to the application** without waiting for the buffer to fill.
Example: While typing commands in **Telnet or SSH**, each keystroke may be sent with the **PSH** flag.

URG (Urgent): Indicates the presence of **urgent data** that should be processed immediately; the urgent pointer field is valid.
Example: Pressing **Ctrl+C** in a remote terminal can generate urgent data marked with the **URG** flag.

Port Scanning with Nmap

Port scanning is the process of probing a target system to identify:

- Open ports
- Running services
- Service versions

Basic Nmap Syntax

nmap [scan_type] [options] target

TCP Connect Scan (-sT) : nmap -sT target

- Completes full TCP handshake
- Easy to detect
- Works without admin privileges

Security note: Logged by servers.

SYN Scan (Stealth Scan) (-sS): nmap -sS target

- Half-open scan
- Faster and stealthier
- Requires admin/root privileges

Security note: Commonly used by attackers.

GLA UNIVERSITY MATHURA

UDP Scan (-sU): nmap -sU target

- Scans UDP services
- Slower and less reliable

Security note: Used to find DNS, SNMP, NTP.

FIN Scan (-sF): nmap -sF target

- Uses FIN flag

Bypasses some firewalls

Service Detection (-sV): nmap -sV target

- Identifies service type and version
- Helps locate vulnerable software

OS Detection (-O): nmap -O target

- Identifies operating system

Uses TCP/IP stack fingerprinting

Attacks Across Network Layers

Attacks Across Network Layers refer to cyberattacks that target **different layers of the network model (OSI/TCP-IP)**. Instead of attacking only applications, attackers exploit weaknesses at **any layer**, from physical hardware to software services.

Why it is Important:

- Helps understand **where and how attacks occur**
- Shows that a single security measure is **not enough**
- Enables **layered security (Defense-in-Depth)**
- Improves **attack detection, prevention, and response**
- Reduces risk of **data breaches and service downtime**

Physical Layer Attacks and Countermeasures

Deals with **hardware and transmission**; attacks disrupt or damage network components. Attach includes

- Cable tapping
- Hardware damage
- Power interruption
- Device theft

Impact

- Network outage
- Data interception

Countermeasures

- Physical security
- Surveillance
- Access control

GLA UNIVERSITY MATHURA

Physical Layer Attacks and Countermeasures

Deals with **hardware and transmission**; attacks disrupt or damage network components. Attach includes

- Cable tapping
- Hardware damage
- Power interruption
- Device theft

Impact

- Network outage
- Data interception

Countermeasures

- Physical security
- Surveillance
- Access control

GLA UNIVERSITY MATHURA

Data Link Layer Attacks and Countermeasures

Handles local data transfer; attacks exploit address and **frame** handling .

Attacks includes:

- MAC spoofing
- ARP poisoning
- VLAN hopping

Impact

- Man-in-the-Middle (MITM)
- Network sniffing

Countermeasures

- Port security
- Dynamic ARP inspection
- VLAN configuration

GLA UNIVERSITY MATHURA

Network Layer Attacks and Countermeasures

Manages routing and IP addressing; attacks affect **packet** delivery . Attacks includes:

- IP spoofing
- ICMP flooding
- Routing attacks (BGP hijacking)

Impact

- Traffic redirection
- Denial of Service (DoS)

Countermeasures

- Firewalls
- Packet filtering
- Secure routing protocols

GLA UNIVERSITY MATHURA

Transport Layer Attacks and Countermeasures

Ensures end-to-end communication; attacks disrupt connections and services . Attacks includes:

- SYN flood attack
- TCP session hijacking
- UDP flood

Impact

- Service unavailability
- Connection disruption

Countermeasures

- SYN cookies
- Rate limiting
- IDS/IPS

GLA UNIVERSITY MATHURA

Session Layer Attacks and Countermeasures

Manages user sessions; attacks target session control and continuity . Attacks includes:

- Session hijacking
- Session fixation

Impact

- Unauthorized access
- Account takeover

Countermeasures

- Secure session IDs
- Timeout policies
- Encryption

GLA UNIVERSITY MATHURA

Presentation Layer Attacks and Countermeasures

Handles data format and encryption; attacks compromise data protection

Attacks includes:

- SSL stripping
- Data manipulation
- Encryption attacks

Impact

- Data exposure
- Loss of confidentiality

Countermeasures

- Strong encryption (TLS)
- Certificate validation

GLA UNIVERSITY MATHURA

Application Layer Attacks and Countermeasures

Provides user services; attacks target applications and user data. Attacks includes:

- SQL Injection
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Malware

Impact

- Data breach
- System compromise

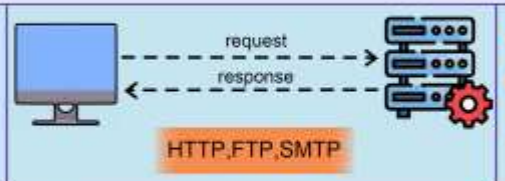
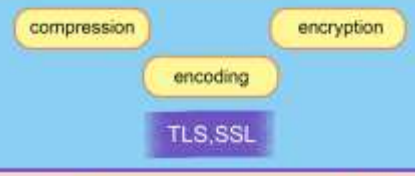
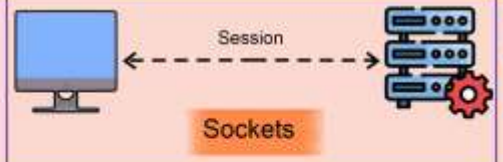
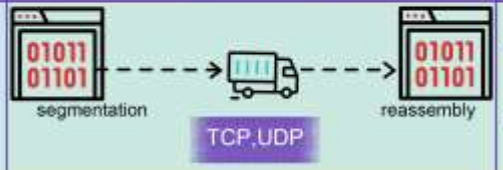
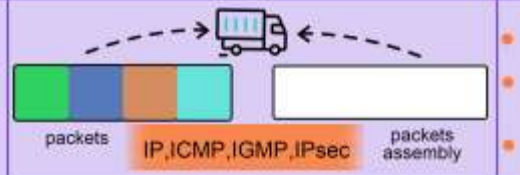
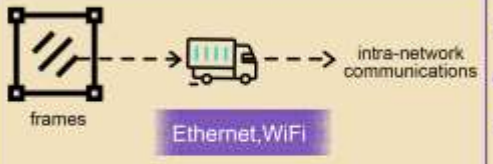
Countermeasures

- Input validation
- Secure coding
- Web Application Firewalls (WAF)

GLA UNIVERSITY MATHURA

Top Network Security Cheatsheet

ByteByteGo

7.Application Layer		• SQL Injection • Cross-Site Scripting (XSS) • DDos attacks
6.Presentation Layer		• Character Encoding Attacks • SSL Striping • Data Compression Manipulation
5.Sesion Layer		• Session replay • Session fixation attacks • Man-in-the-middle attacks
4.Transport Layer		• UDP flood • SYN flood
3.Network Layer		• IP spoofing • Route table manipulation • Smurf attack
2.Data Link Layer		• MAC address spoofing • ARP spoofing • Switch flooding
1.Physical Layer		• Eavesdropping/Tapping • Physical tampering • Electromagnetic interference

GLA UNIVERSITY MATHURA

Network Access Control (NAC)

Network Access Control (NAC) is a critical cybersecurity solution that manages access to **private networks by authenticating users and verifying device,** compliance with security policies. It enhances security by preventing unauthorized access, identifying compromised devices, and enforcing **Zero Trust principles**. Key functions include pre-admission scanning, post-admission monitoring, and quarantining devices

It

- **Prevents Unauthorized Access:** Blocks "rogue" or unknown devices from entering the corporate environment.
- **Enables Secure IoT and BYOD:** Safely manages personal employee devices by enforcing company security policies.
- **Simplified Guest Access:** Automates secure internet-only access for visitors via self-service portals.
- **Supports Zero Trust:** Continuously verifies every connection request
- **Regulatory Compliance:** Provides detailed logs and reports required for standards for audits.

NAC Core Functions and Benefits

Authentication & Authorization: Ensures only validated users and secure, authorized devices can connect.

Visibility: Provides comprehensive insight into all devices on the network, essential for BYOD and IoT management.

Policy Enforcement: Checks device health (e.g., antivirus status, patches) before granting access.

Threat Prevention: Detects and quarantines compromised devices to prevent the spread of malware.

Compliance: Helps meet regulatory requirements (e.g., HIPAA, PCI DSS) for data protection.

GLA UNIVERSITY MATHURA

NACs differ from firewalls

Feature	Firewall	Network Access Control (NAC)
Primary Focus	Filters data flow (traffic) based on IP, port, or protocol.	Verifies identity and compliance of devices/users.
Network Position	Acts as a perimeter gatekeeper between different networks (e.g., Internet vs. Internal).	Operates at the access layer (where devices physically or wirelessly connect).
Control Unit	Monitors "packets" and "sessions".	Manages "endpoints" and "identities".
Policy Type	Generally static rules (allow/deny).	Dynamic policies based on device "posture" (e.g., antivirus status).
Visibility	Sees traffic passing through it.	Sees every device connected to the LAN/WLAN.

GLA UNIVERSITY MATHURA

IP & Transport Security

IPSec (Internet Protocol Security)

IPSec (Internet Protocol Security) is a suite of protocols used to secure Internet Protocol (IP) communications by authenticating and encrypting each IP packet in a communication session. It operates at the **network layer** and can be used to protect data flows between hosts and a network.

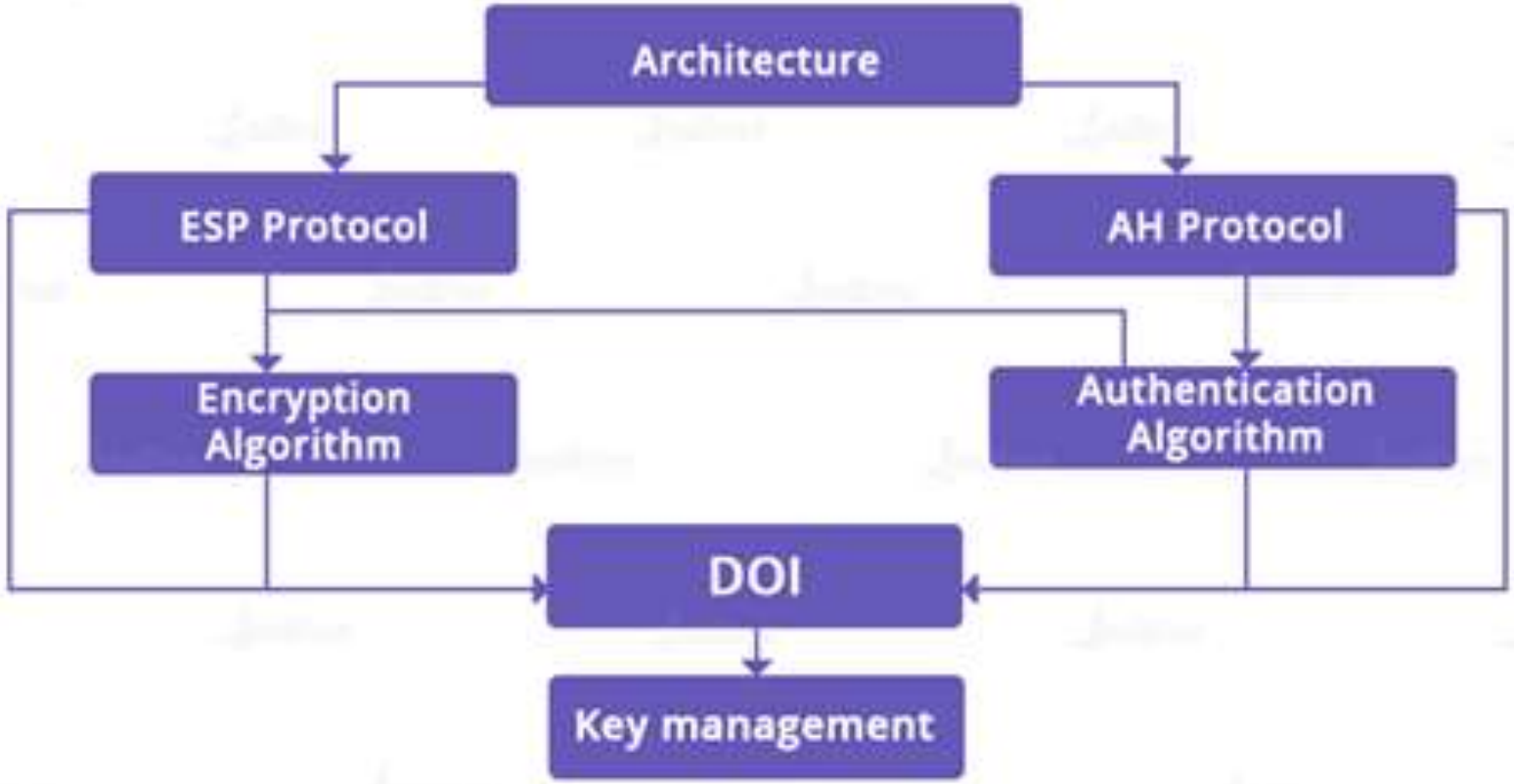
Main Features:

- **Confidentiality**
- **Integrity**
- **Authentication** (verifying the source)
- **Anti-replay protection** (to prevent packet re-transmission)

IPSec Architecture

IPsec has **following core components**:

- **Authentication Header (AH)**
- **Encapsulating Security Payload (ESP)**
- **Domain of Interpretation (DOI)**
- **Internet Key Exchange (IKE)**



Authentication Header (AH)

AH provides **authentication and integrity** for IP packets but **does not provide encryption**.

Security Services Provided

- Data integrity
- Source authentication
- Anti-replay protection
- ❌ **No confidentiality** (payload is not encrypted)

How AH Works

- AH inserts a header between the IP header and payload
- Computes a **hash (HMAC)** over:
  - Payload
  - Immutable IP header fields
- Any modification during transit is detected.

Use Case

- When **authentication is required** but **encryption is not mandatory**
- Rarely used today due to incompatibility with NAT

GLA UNIVERSITY MATHURA

Encapsulating Security Payload (ESP)

ESP provides **encryption, integrity, and authentication**, making it the **primary protocol used in IPsec VPNs**.

Security Services Provided

- Data encryption
- Data integrity
- Source authentication
- Anti-replay protection

How ESP Works

- Encrypts the **payload** using symmetric encryption (AES, 3DES)
- Optionally authenticates the packet
- Can operate with or without authentication (encryption-only mode is possible)

ESP Modes

- **Transport Mode** – protects payload only
- **Tunnel Mode** – encapsulates entire IP packet (used in VPNs)

Use Case

1. VPNs (site-to-site and remote access)
2. Secure communication over untrusted networks

GLA UNIVERSITY MATHURA

Internet Key Exchange (IKE)

IKE securely negotiates **keys and security associations**, enabling AH and ESP to function safely.

Functions of IKE

- Authenticates communicating parties
- Negotiates security algorithms
- Performs key exchange securely

IKE Phases

◆ **Phase 1 – Secure Channel Establishment**

- Establishes a secure, authenticated channel
- Uses Diffie–Hellman for key exchange
- Modes:

◆ **Phase 2 – IPsec SA Negotiation**

- Negotiates AH/ESP parameters
- Generates keys for data protection
- Result: **IPsec SA**

Transport Modes

In Transport Mode, only the **payload** (the actual data being sent, like an HTTP request or a file chunk) is encrypted or authenticated. The original IP header remains untouched and visible. **Transport Mode** secures **only the payload (data portion)** of the original IP packet, while the **original IP header remains visible**.

How it works: The IPsec header is inserted after the IP header but before the upper-layer protocol (like TCP or UDP).

Visibility: Routers along the path can see the original source and destination IP addresses.

Best Use Case: End-to-End communication. This is used when two hosts (like two workstations) want to secure a direct conversation.

Choose Transport Mode if you are managing the security on the individual devices themselves and don't mind the "traffic map" (who is talking to whom) being visible.

Tunnel Mode

In Tunnel Mode, the **entire original IP packet** (header + payload) is encrypted and then encapsulated inside a brand-new IP packet with a new header.

How it works: Think of it as putting a sealed letter inside a completely new envelope. The "inner" packet is hidden; the "outer" header directs the packet between security gateways.

Visibility: Intermediate routers only see the IP addresses of the two "tunnel endpoints" (usually firewalls or VPN gateways), not the actual source or destination devices.

Best Use Case: Site-to-Site VPNs. This is the standard for connecting a branch office to a main headquarters over the public internet.

Choose Tunnel Mode if you are setting up a VPN or need to hide the internal network topology from the outside world.

GLA UNIVERSITY MATHURA

Feature	Transport Mode	Tunnel Mode
Protects	Payload only	Entire IP packet
IP Header	Visible	Hidden (encrypted)
New IP Header	❌ No	✅ Yes
Overhead	Low	Higher
Typical Use	Host ↔ Host	VPNs (Gateway ↔ Gateway)
Security Level	Moderate	High

GLA UNIVERSITY MATHURA

IP Security Policies

An **IP Security Policy** is a **set of rules** that determine the **security treatment of IP packets** based on defined conditions such as source/destination, protocol, and ports. Each rule answers three questions:

- **Which traffic?**
- **What action?** (Protect / Bypass / Discard)
- **How to protect?** (AH/ESP, mode, algorithms)

IPsec policies are primarily managed through two databases:

- **Security Policy Database (SPD):** It contains a set of rules that compare the packet's "selectors" (Source IP, Destination IP, Port, Protocol) against a defined action.
- **Security Association Database (SADB):** The SADB is a local database maintained on every IPsec-enabled device. It stores all the active **Security Associations (SAs)**.

GLA UNIVERSITY MATHURA

Transport Layer Security (TLS)

Transport Layer Security (TLS) is a cryptographic protocol designed to provide secure communication over a computer network, most commonly the internet. It ensures **confidentiality, integrity, and authentication** between two communicating applications (e.g., a web browser and a server).

Key Features of TLS:

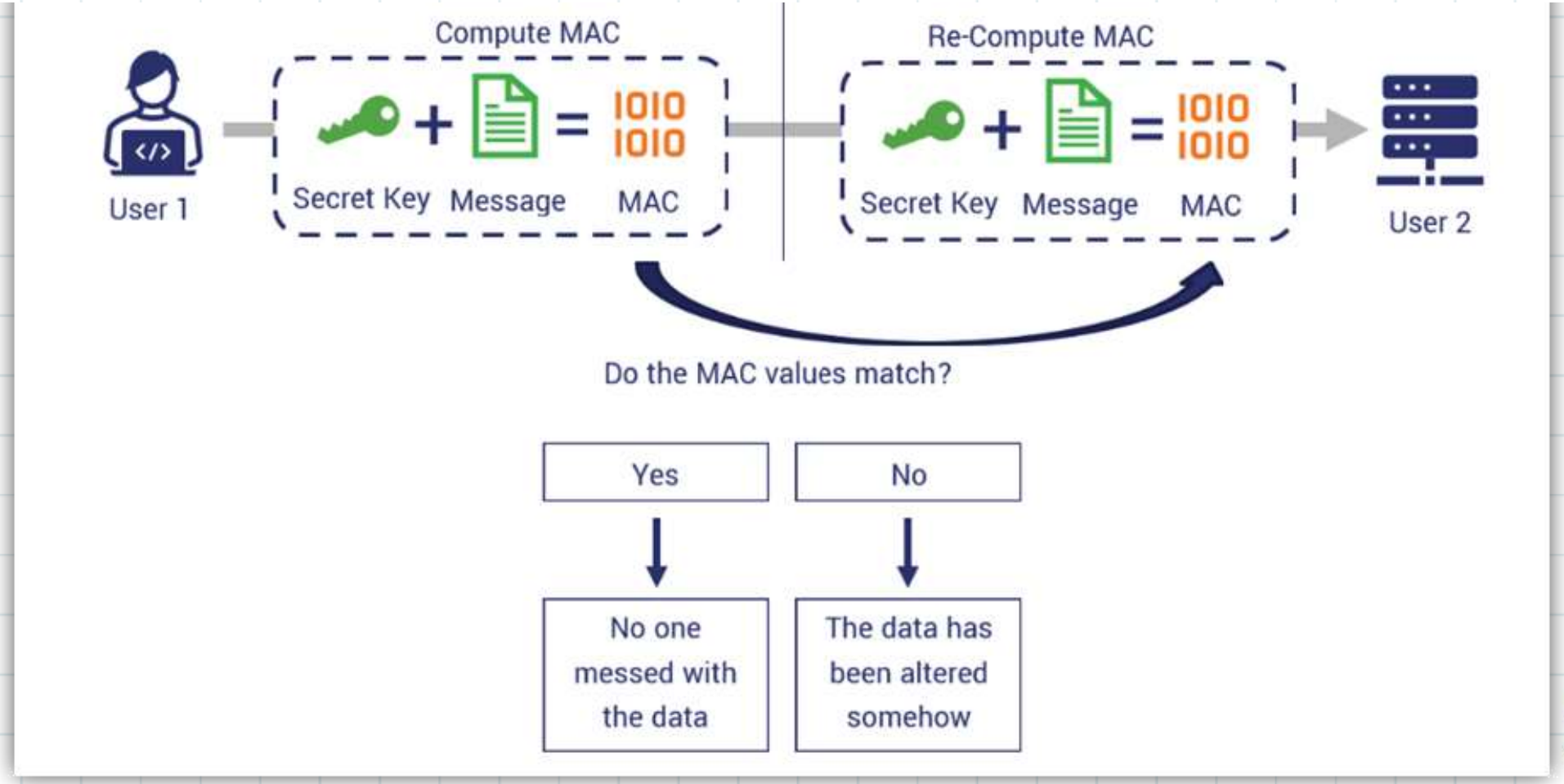
1. **Encryption (Confidentiality)**
    1. Uses symmetric encryption to protect data from eavesdropping.
    2. Asymmetric encryption is used during the handshake to establish a shared secret.

2. **Data Integrity (Tamper-proofing)**
    1. Uses **Message Authentication Codes (MACs)** to detect tampering.

3. **Authentication (Preventing Impersonation)**
    1. Servers (and optionally clients) are authenticated using **digital certificates** (X.509) issued by trusted **Certificate Authorities (CAs)**.
    2. Public Key Infrastructure (PKI) ensures trust in certificates.

Message Authentication Code (MAC)

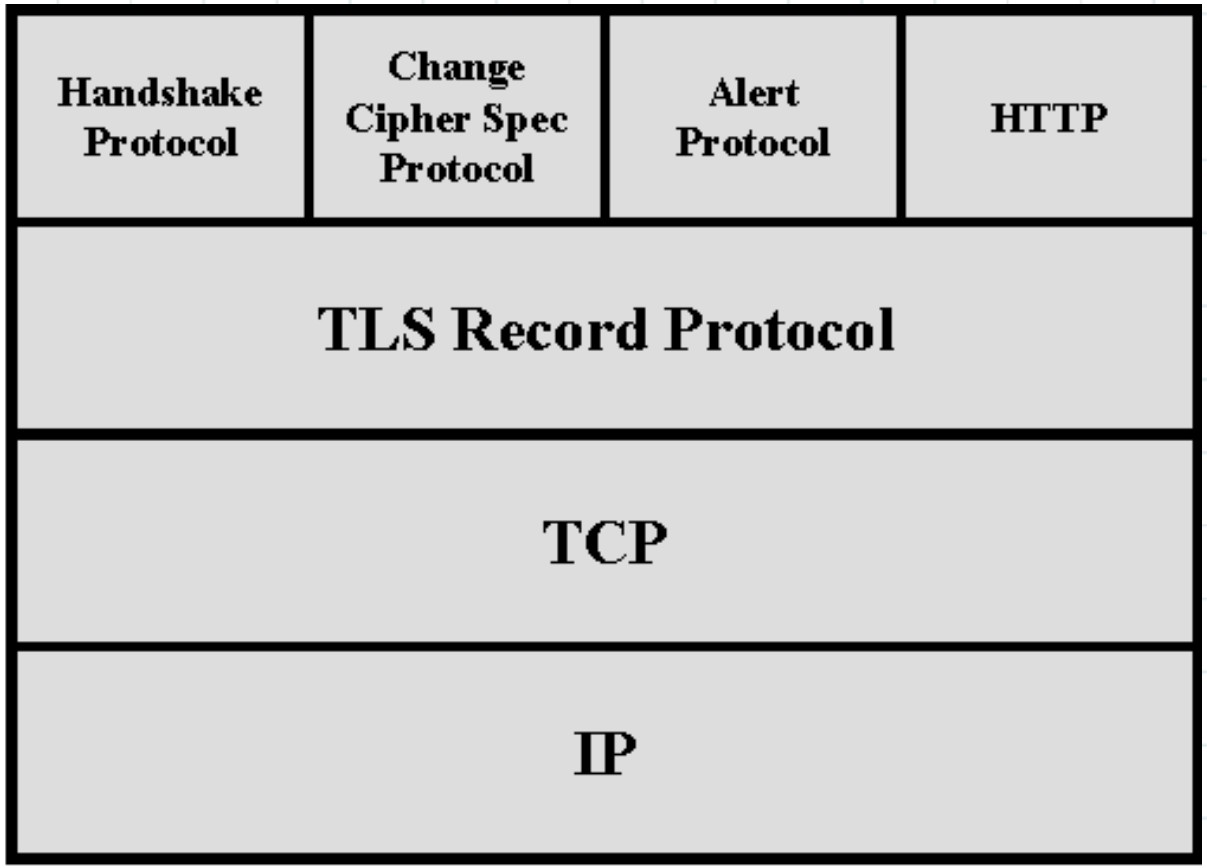
A **Message Authentication Code (MAC)** is a short piece of information used to authenticate a message and ensure its integrity.



TLS Architecture

TLS has two main layers:

- **Handshake Protocol:** Establishes security parameters (keys, algorithms, authentication).
- **Record Protocol:** Encrypts, compresses, fragments, and MAC-protects application data.



TLS Record Protocol

It takes application data, protects it (encryption + integrity), and sends it safely across the network. It provides the core security services: confidentiality (through encryption) and message integrity (through a Message Authentication Code, or MAC).

- **Fragmentation:** It breaks higher-level data into manageable blocks.
- **Compression:** (Optional and rarely used now due to security vulnerabilities like CRIME).
- **Encryption & MAC:** It applies the security parameters negotiated by the upper-layer protocols.

GLA UNIVERSITY MATHURA

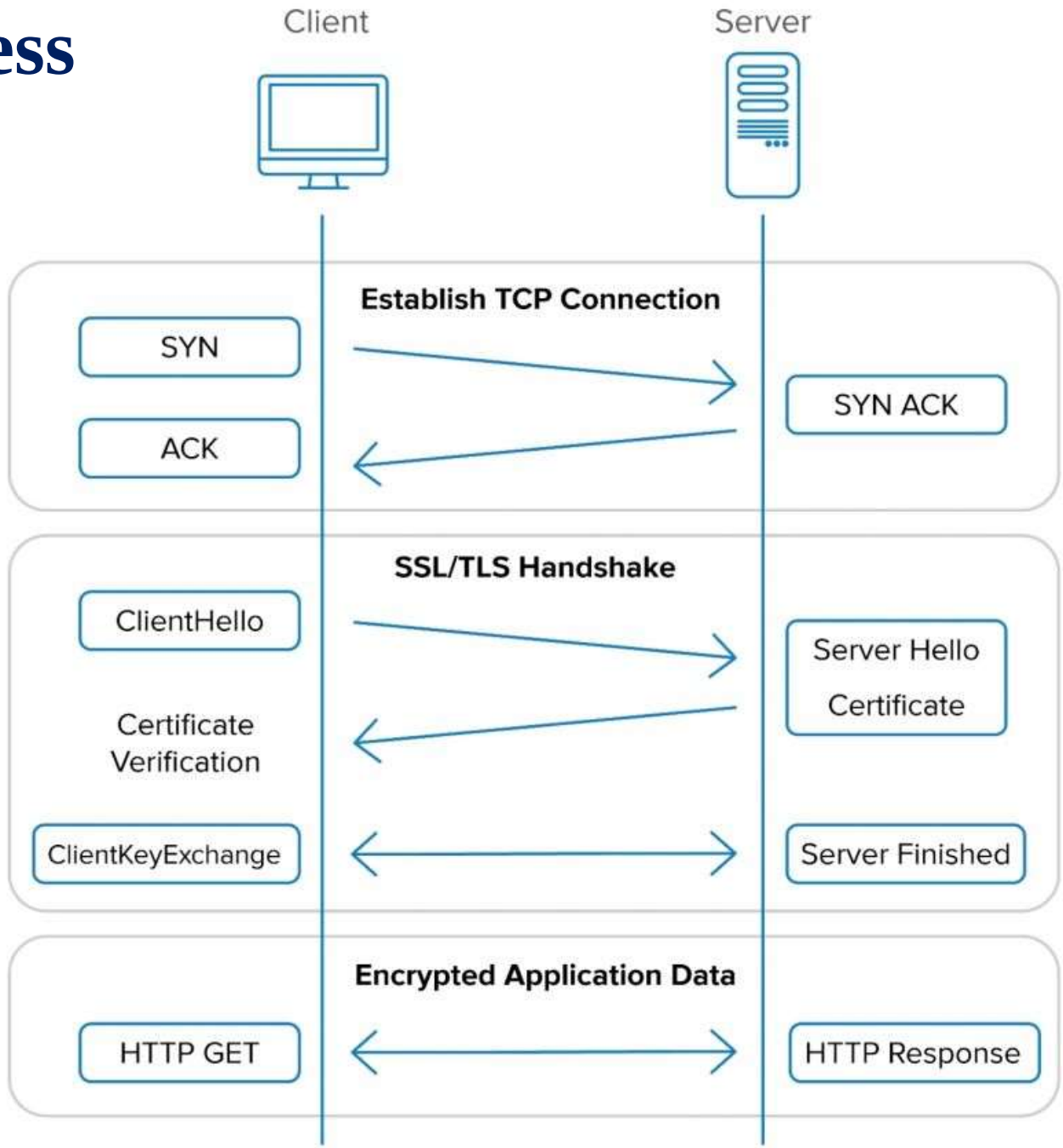
TLS Handshake

- A sender sends a ClientHello. This includes information about Client.
- Then server responds with ServerHello message (selecting highest version of TLS supported by Client) and then chooses a cipher suite from list in ClientHello message. The server also transmits its Digital certificate and a final ServerHelloDone message.
- Client validates certificate. Client then sends ClientKeyExchange message. Here client chooses a key exchange mechanism to securely establish a shared secret with server. Client also needs to send ChangeCipherSpec indicating that it is switching to secure communication now, which is finally followed by Finished message for indicating a successful handshake.
- Server replies with ChangeCipherSpec and an encrypted Finished message once shared secret is received.

While the ***Handshake Protocol*** is busy doing the fancy introductions and exchanging keys, the **Record Protocol** stays in the background doing the heavy lifting of moving actual data.

GLA UNIVERSITY MATHURA

Handshake Process



GLA UNIVERSITY MATHURA

TLS Certificate

A **TLS certificate** is a **digital certificate (X.509 format)** used to **authenticate the identity of a server (and optionally a client)** in a TLS connection. It binds a **public key** to an entity such as a website or organization.

Key Components of a TLS Certificate

- Subject (domain name)
- Public key
- Certificate Authority (CA) signature
- Validity period
- Serial number

Role in TLS

- Enables **server authentication**
- Supports **secure key exchange**

GLA UNIVERSITY MATHURA

TLS Vulnerabilities

1. Protocol Downgrade Attacks

- Forces use of older TLS/SSL versions
- Exploits weaker cryptography

2. Weak Cipher Suites

- Use of RC4, DES, MD5
- Easily breakable encryption

3. Misconfiguration (Most Common Today):

Modern attacks often succeed because of

- Old TLS versions enabled
- Poor key management

4. Certificate Validation Errors

- Accepting self-signed or fake certificates
- Enables MITM attacks

Mitigation Measures

- Disable SSL & old TLS versions
- Use strong cipher suites (AES, SHA-256)
- Enable certificate validation
- Apply timely patches

GLA UNIVERSITY MATHURA

HTTPS

HTTPS is the secure version of HTTP that uses **TLS** to protect data exchanged between a client (browser) and a web server.

Security Services Provided by HTTPS

- Confidentiality (encryption)
- Integrity (tamper detection)
- Authentication (server identity)

How HTTPS Works

- Client initiates HTTPS request
- TLS handshake begins
- Server sends TLS certificate
- Secure session key is established
- Encrypted HTTP communication starts

GLA UNIVERSITY MATHURA

SSH (Secure Shell)

SSH (Secure Shell) is a **secure remote login and command execution protocol** that replaces insecure protocols like Telnet.

Security Services Provided by SSH

- Encryption of data
- Server authentication
- Client authentication
- Secure tunneling

How SSH Works

- Client connects to SSH server
- Server authentication using host keys
- Client authentication (password or key-based)
- Encrypted session established

Uses of SSH

- Remote system administration
- Secure file transfer (SCP/SFTP)
- Port forwarding and tunneling

GLA UNIVERSITY MATHURA

Security Policies & Countermeasures

Security Policies

A **security policy** is a formal document that defines **what is allowed and what is not allowed** in an organization's information system.

Key purposes

- Define acceptable use of network resources
- Specify access control rules
- Establish responsibilities and enforcement mechanisms
- Act as a baseline for implementing security controls

Why policies matter

- Technology alone cannot ensure security
- Policies convert **security goals → enforceable rules**
- Provide legal and compliance backing

GLA UNIVERSITY MATHURA

Mutual Trust Mechanisms

Mutual trust mechanisms ensure **both communicating entities authenticate each other**, not just one side.

1. Mutual Authentication

- Both client and server verify each other's identity before communication.

Used in

- Secure VPNs
- TLS with client certificates
- Kerberos authentication

Benefits

- Prevents impersonation

Mutual Trust Mechanisms

2 Common Mutual Trust Techniques

(a) Shared Secret–Based Trust

- Passwords or pre-shared keys
- **Weakness**: Vulnerable to replay and brute-force attacks

(b) Public Key–Based Trust

- Uses asymmetric cryptography
- Digital certificates bind identity to public keys
- Foundation of **TLS, IPsec, PKI**

3 Trust Models

- **Centralized Trust**: Certificate Authorities (CAs)
- **Decentralized Trust**: Web of Trust (PGP)
- **Federated Trust**: SAML, enterprise identity systems

Network-Level Security Measures (Layer 3)

These measures focus on protecting data as it moves across the wire, ensuring that "man-in-the-middle" (MITM) attackers cannot read or alter the traffic.
Security at this level is transparent to the user. It protects the entire packet, including the IP header.

Key Techniques

Firewalls

- **Packet filtering:** Allows or blocks packets based on IP, port, or protocol rules.
- **Application-aware firewalls:** Control traffic based on actual application being used

IP Spoofing Protection

- **Ingress and egress filtering:** Blocks packets with fake source IP addresses entering or leaving a network.
- **Reverse Path Forwarding (RPF):** Drops packets if their source address is not reachable via the correct route.

Secure Routing Protocols

- **Authentication of routing updates:** Ensures routing messages come from trusted routers.
- **Protection against route hijacking:** Prevents attackers from redirecting network traffic.

IPsec

- **Encrypts and authenticates IP packets:** Protects data from being read or modified in transit.
- **Works transparently to applications:** Security works without changing applications

Transport-Level Security Measures (Layer 4)

This layer secures data transfer by **preventing session attacks, blocking connection floods, controlling open ports, and encrypting communication**. It ensures connections remain secure and resources are not overwhelmed by attackers.

Key Threats

- **Session hijacking:** Attacker takes over an active communication session between two systems.
- **SYN flood attacks:** Attacker sends many connection requests to exhaust server resources.
- **Port scanning:** Attacker scans ports to find open services to attack.

Countermeasures

- **TCP SYN Cookies:** Server avoids storing connection data until the client proves it is legitimate, preventing overload.
- **Port Hardening:** Unused ports and services are disabled to reduce attack points.
- **Transport Encryption (TLS over TCP):** Data is encrypted during transmission to prevent eavesdropping or tampering.
- **Session Timeouts & Re-keying:** Sessions expire or keys change regularly to reduce the time attackers can exploit a connection.

GLA UNIVERSITY MATHURA

IP Security (IPsec)

IPsec is a suite of protocols used to secure IP communications by authenticating and encrypting each IP packet in a communication session.

Authentication Header (AH): Provides connectionless integrity and data origin authentication, but **does not** provide encryption.

Encapsulating Security Payload (ESP): Provides the "heavy lifting"—confidentiality (encryption) and authentication.

Modes of Operation:

- **Transport Mode:** Only the payload is encrypted; used for end-to-end communication.
- **Tunnel Mode:** The entire IP packet is encrypted and wrapped in a new IP header; used for VPNs.

GLA UNIVERSITY MATHURA

TLS Countermeasures

Perfect Forward Secrecy (PFS): Ensures that if a long-term private key is compromised, past sessions remain encrypted.

HSTS (HTTP Strict Transport Security): Forces the browser to connect via HTTPS only, preventing "downgrade attacks.“

Certificate Pinning: Tells the client to trust only a specific certificate, preventing attackers from using fraudulent CAs.

TLS 1.3 Adoption: Removes obsolete, weak cryptographic algorithms (like SHA-1 and MD5) to streamline the handshake.

Email Security

Phishing

Phishing is a broad term for fraudulent attempts to obtain sensitive information—such as usernames, passwords, and credit card details—by disguising oneself as a trustworthy entity in an electronic communication.

Common Types of Phishing

- **Spear Phishing:** Unlike general phishing, this is a targeted attack directed at a specific individual or organization. The attacker often researches the victim beforehand.
- **Whaling:** A high-stakes version of spear phishing aimed at "big fish," like CEOs or CFOs.
- **Vishing & Smishing:** Phishing via voice calls (Vishing) or SMS/text messages (Smishing).

How It Works

- **The Bait:** You receive an email that looks like it’s from your bank, Netflix, or Google.
- **The Hook:** The email claims there is a "security breach" or an "unpaid invoice" to create a sense of urgency.
- **The Catch:** You click a link to a fake login page. Once you enter your credentials, the attacker steals them.

Best Practices Against Phishing Attacks

- Verify sender email addresses and domain names carefully
- Do not click suspicious links or download unknown attachments
- Use multi-factor authentication (MFA) on all critical accounts
- Check URLs by hovering before clicking
- Report suspicious emails to IT/security teams
- Keep software and antivirus tools updated
- Use strong, unique passwords for each account
- Be cautious with urgent or fear-based messages
- Regularly attend security awareness training

Business Email Compromise (BEC)

BEC is a more sophisticated and financially motivated exploit. It doesn't usually involve malicious links or malware; instead, it relies on identity theft and authority.
Core Tactics

Executive Spoofing: An attacker poses as a CEO and emails a lower-level employee in the finance department, requesting an "urgent" wire transfer for a secret acquisition.

Inbound Invoice Fraud: Attackers compromise a vendor’s email account. They then send a real-looking invoice to the vendor's clients but change the bank account details to their own.

Account Takeover (ATO): The attacker gains actual access to a legitimate corporate email account, making their fraudulent requests nearly impossible to detect.

GLA UNIVERSITY MATHURA

Email Authentication

Email authentication is a multi-layered defense system designed to prove that an email is genuinely from who it claims to be. Without these protocols, the Simple Mail Transfer Protocol (SMTP)—the foundation of email—is easily "spoofed," allowing attackers to forge the "From" address.

Modern email security relies on a "Holy Trinity" of domain-level protocols (**SPF, DKIM, and DMARC**) and an optional user-level encryption standard (**PGP**).

GLA UNIVERSITY MATHURA

SPF (Sender Policy Framework)

SPF (Sender Policy Framework) is an **email authentication method** used to help prevent **email spoofing** and reduce spam.

What SPF does

SPF lets a domain owner specify **which mail servers are allowed to send email on behalf of their domain**.

When a receiving mail server gets an email, it:

- Checks the sending domain.
- Looks up that domain's **SPF record** in DNS.
- Verifies whether the sending server is authorized.
- Accepts, flags, or rejects the email based on the result.

Why SPF matters

- Without SPF, attackers can easily forge emails that appear to come from your domain. SPF helps:
- Reduce phishing and spoofing
- Improve email deliverability
- Protect domain reputation

GLA UNIVERSITY MATHURA

DKIM (DomainKeys Identified Mail)

DKIM (DomainKeys Identified Mail) is an **email authentication method** that helps ensure an email was **not altered in transit** and truly comes from the claimed domain.

What DKIM does

- DKIM adds a **digital signature** to outgoing emails.
  Receiving mail servers use this signature to verify the message.

How DKIM works

- The sending mail server adds a **DKIM signature** to the email header.
- The domain publishes a **public key** in DNS.
- The receiving server retrieves the public key.
- It verifies the signature.
- If valid, the email is confirmed as authentic and unchanged.

Why DKIM matters

- Prevents email tampering
- Confirms sender domain authenticity
- Improves email deliverability
- Helps prevent phishing and spoofing

GLA UNIVERSITY MATHURA

DMARC (Domain-based Message Authentication, Reporting, and Conformance)

DMARC is an email authentication protocol that helps domain owners **protect their domain from spoofing and phishing** while also receiving reports about email authentication results.

What DMARC does: DMARC builds on **SPF** and **DKIM** and tells receiving mail servers:

- How to handle emails that fail authentication.
- Where to send reports about those failures.

How DMARC works

- An incoming email is checked using **SPF and/or DKIM**.
- DMARC verifies whether the results align with the sender's domain.
- Based on the domain's DMARC policy, the receiver:
    - Accepts,
    - Sends to spam, or
    - Rejects the email.
- Reports are sent back to the domain owner.

DMARC policy options

- **p=none** → Monitor only (no action taken)
- **p=quarantine** → Send suspicious mail to spam
- **p=reject** → Block unauthorized mail

PGP (Pretty Good Privacy)

PGP (Pretty Good Privacy) is an **encryption program** used to secure emails and files by providing **privacy, authentication, and data integrity**.

What PGP does

- PGP protects information by:
- Encrypting messages so only the intended recipient can read them.
- Digitally signing messages to verify the sender's identity.
- Ensuring data has not been altered.

How PGP works: PGP uses **public-key cryptography** with two keys:

- **Public Key** – Shared with others; used to encrypt messages sent to you.
- **Private Key** – Kept secret; used to decrypt messages and create digital signatures.

Process

- Sender encrypts the message using the recipient's public key.
- Recipient decrypts it using their private key.
- Sender can also digitally sign the message to prove authenticity.

GLA UNIVERSITY MATHURA

Secure Email Protocols

Email communication is the backbone of digital interaction, but the original protocols were designed in a more "innocent" era of the internet—meaning they sent data in plain text. Today, securing these protocols is the only thing standing between your private messages and a bored hacker on public Wi-Fi.

GLA UNIVERSITY MATHURA

SMTP (Simple Mail Transfer Protocol)

SMTP is the **delivery man** of the email world. It is used to send emails from a client (like Outlook) to a server, or between servers.

Role of SMTP

Used for **sending and relaying emails**

Operates between:

- Client → Mail server
- Mail server → Mail server

Default Ports

- **25** – Server-to-server transfer
- **587** – Message submission (recommended)

Security Issues in SMTP

- No built-in authentication
- No encryption by default
- Vulnerable to: Email spoofing, Man-in-the-Middle (MITM) attacks, Eavesdropping, Spam relaying

GLA UNIVERSITY MATHURA

POP3 (Post Office Protocol v3)

POP3 is the "old school" method. It typically downloads the email to your device and **deletes it from the server**.

Role of POP3

- Used by clients to **download emails from server**
- Emails are usually **deleted from server after download**

Default Ports

- **110** – Plain POP3
- **995** – POP3S (POP3 over SSL/TLS)

Security Issues in POP3

- Credentials sent in clear text
- No message integrity
- Vulnerable to: Password sniffing, Session hijacking

Limitations

- No synchronization across devices
- Poor support for modern multi-device access

GLA UNIVERSITY MATHURA

IMAP (Internet Message Access Protocol)

IMAP is the modern standard. it leaves the email on the server and **syncs** it across multiple devices.

Role of IMAP

- Emails remain **stored on the server**
- Supports:
  - Folder management
  - Multi-device synchronization
  - Server-side search

Default Ports

- **Port 143 –** Standard IMAP (not encrypted by default)
- **Port 993 –** IMAPS (IMAP over SSL/TLS, encrypted and recommended)

Security Issues in IMAP

- Plain-text authentication without encryption
- Vulnerable to MITM and credential theft

GLA UNIVERSITY MATHURA

STARTTLS

STARTTLS is a protocol extension that **upgrades an existing plaintext connection into an encrypted TLS session**.
Used with:

- SMTP
- POP3
- IMAP

How STARTTLS Works

- Client connects in plaintext
- Server advertises STARTTLS capability
- TLS handshake begins
- Communication continues securely

Security Benefits

- Encryption in transit
- Protection against eavesdropping
- Server authentication via certificates

Security Risks: Downgrade attacks

GLA UNIVERSITY MATHURA

Operational differences of SMTP, POP3, and IMAP protocols

Feature	SMTP	POP3	IMAP
Purpose	Sends emails	Downloads emails to client	Accesses emails on server
Main Role	Client → Server & Server → Server transfer	Retrieves emails, usually removes from server	Keeps emails on server and syncs devices
Default Ports	25, 587	110, 995 (secure)	143, 993 (secure)
Storage Location	Not for storage	Emails stored on local device	Emails stored on server
Multi-device Support	Not applicable	Poor, mainly single device	Yes, full synchronization
Best Use Case	Sending email between servers and clients	Single-device offline email access	Accessing mail on multiple devices

Usage scenarios of SMTP, POP3, and IMAP

Protocol	Suitable Usage Scenario
SMTP	Used when sending emails from clients to mail servers or between mail servers. Essential for email delivery systems and applications sending automated emails.
POP3	Suitable when email is accessed on one device only or when users need offline local storage and want to reduce server storage usage.
IMAP	Best when users access email from multiple devices (phone, laptop, webmail) and need synchronized folders and messages. Ideal for modern organizations and cloud email services.

Malware

Malware is malicious software designed to damage systems, steal data, or disrupt operations. Types include:

- **Viruses** – Malicious programs that attach to files and spread when infected files are opened, potentially damaging data or systems.
- **Trojans** – Malware disguised as legitimate software that tricks users into installing it, allowing attackers to access or control systems.
- **Spyware** – Software that secretly monitors user activities and steals personal or sensitive information.
- **Worms** – Self-replicating malware that spreads automatically across networks without user action.
- **Ransomware** – Malware that encrypts files or systems and demands payment to restore access.

Ransomware

Ransomware encrypts an organization's data or systems and demands payment for restoration. Modern attacks may also steal data before encryption.

Effects include:

- Business downtime
- Financial loss
- Reputational damage
- Legal consequences

Common Types of Ransomware

- **Crypto Ransomware** – Encrypts files and demands payment for decryption.
- **Locker Ransomware** – Locks users out of the system.
- **Double Extortion Ransomware** – Encrypts and steals data.
- **Ransomware-as-a-Service (RaaS)** – Criminal groups sell ransomware tools to other attackers.

GLA UNIVERSITY MATHURA

Best Practices Against Ransomware Attacks

- Keep operating systems and applications regularly updated
- Maintain secure, offline, and tested data backups
- Use strong passwords and enable multi-factor authentication (MFA)
- Avoid clicking suspicious links or email attachments
- Install and regularly update antivirus/endpoint protection
- Restrict user access rights based on job roles (least privilege)
- Train employees on ransomware and phishing awareness

MFA

MFA (Multi-Factor Authentication) is a security method that requires users to verify their identity using **two or more authentication factors** before accessing an account or system.

Common factors include:

- **Something you know** – Password or PIN
- **Something you have** – Phone, security token, or OTP code
- **Something you are** – Fingerprint or facial recognition

Benefit: Even if a password is stolen, attackers cannot access the account without the additional verification factor.

GLA UNIVERSITY MATHURA

Best Practices to Prevent and Mitigate phishing and ransomware attacks

1) Continuous Employee Security Awareness Training

- Recognize phishing emails and suspicious links
- Verify unexpected requests for credentials or payments
- Report suspicious activity quickly
- Understand safe browsing and email practices
- Regular simulated phishing exercises reinforce awareness.

2) Implement Strong Access Controls and Multi-Factor Authentication (MFA)

- Enable **MFA** for email, VPNs, and internal systems
- Apply **least-privilege access** so users only have necessary permissions
- Monitor unusual login attempts and access patterns
- Even if credentials are stolen, MFA reduces unauthorized access.

3) Maintain Secure, Tested Backups and Incident Response Plans

- Keep **regular, automated, and offline/immutable backups**
- Test restoration processes regularly
- Maintain a clear incident response plan to reduce downtime
- Organizations can recover without paying ransom if backups are reliable.